

Comprehensive Investigation of CAPTCHA Bypass Techniques and Defenses (2025)

مقدمه

امروزه CAPTCHA (آزمون عمومی کاملاً خودکار برای تشخیص انسان و رایانه) همچنان یکی از ابزارهای اصلی برای جلوگیری از فعالیت‌های خودکار مخرب در وب است. اما پیشرفت‌های هوش مصنوعی و سرویس‌های حل CAPTCHA با نیروی انسانی باعث شده‌اند بسیاری از الگوهای سنتی به راحتی دور زده شوند. در این گزارش، تمام روش‌های شناخته شده برای دور زدن انواع مختلف CAPTCHA بررسی و سپس راهکارهای ایمن‌سازی آن‌ها ارائه می‌شود. در نهایت به نحوه ایجاد CAPTCHAهای بسیار مقاوم که با هیچ روش شناخته شده‌ای قابل bypass نیستند پرداخته می‌شود. برای دستیابی به جامعیت، علاوه بر منابع انگلیسی، منابع آلمانی، فارسی و مقالات علمی ۲۰۲۴-۲۰۲۵ در نظر گرفته شده‌اند.

۱. انواع CAPTCHAs و شیوه‌های حمله

۱.۱ CAPTCHAهای متن محور (Text-Based)

- **ساختار:** تصویری شامل حروف/اعداد تحریف‌شده، خطوط و نویز. امنیت آن‌ها به سختی تفکیک کاراکترها توسط ماشین‌ها متکی است.
- **روش‌های حمله:**
- **الگوریتم‌های یادگیری ماشین:** مهاجمان با جمع‌آوری مجموعه بزرگی از تصاویر CAPTCHA به همراه پاسخ، مدل‌های شبکه عصبی مانند CNN و RNN را آموزش می‌دهند تا الگوهای موجود را یاد بگیرند^۱. فرآیند شامل جمع‌آوری داده، استخراج ویژگی‌ها (شدت پیکسل، اشکال)، آموزش مدل و ارزیابی است^۱.
- **شناخت کاراکتر نوری (OCR):** عکس‌ها پیش‌پردازش شده، نویز و تغییرات حذف و سپس با الگوریتم‌های تطبیق الگو یا SVM/CNN بخش‌بندی می‌شوند^۲. این روش‌ها در بسیاری از CAPTCHAهای ضعیف به دقت بالایی دست یافته‌اند.
- **حملات دور زدن جلسه (session hijacking و token reuse):** برخی سرویس‌ها پس از حل CAPTCHA یک توکن معتبر صادر می‌کنند. مهاجم با سرقت توکن یا تصاحب نشست می‌تواند بررسی‌های بعدی را دور بزند^۳.
- **سرویس‌های حل انسانی:** مهاجمان از «مزارع CAPTCHA» استفاده می‌کنند؛ جایی که کارگران با دستمزد اندک CAPTCHAها را حل کرده و پاسخ را باز می‌گردانند. پژوهش‌ها نشان می‌دهد هزینه حل انسانی کمتر از ۰,۵ دلار برای هر ۱۰۰۰ چالش است^۴.
- **مهندسی اجتماعی و crowdsourcing:** مهاجم کاربران واقعی را فریب می‌دهد تا CAPTCHA را حل کنند، مثلاً با نمایش CAPTCHA در وبسایت جعلی یا توزیع آن میان کارگران crowd-sourcing^۵.

۱.۲ CAPTCHAهای تصویری و انتخابی (Image-Based)

- **ساختار:** کاربر باید همه تصاویر دارای یک شیء خاص (چراغ راهنمایی، دوچرخه و غیره) را انتخاب کند یا قطعه پازل را در جای درست بگذارد.
- **روش‌های حمله:**
- **مدل‌های بینایی عمیق:** شبکه‌های تشخیص شیء مانند YOLO و ResNet که بر روی مجموعه‌های عظیم آموزش دیده‌اند، اکنون می‌توانند با دقت >۹۵٪ اشیای رایج را تشخیص دهند^۶. این مدل‌ها می‌توانند تصاویر CAPTCHA را بخش‌بندی و گزینه صحیح را انتخاب کنند.

- **شبیه‌سازی رفتار انسانی:** در reCAPTCHA v3 با تصاویر پنهان، مهاجمان با شبیه‌سازی حرکت ماوس، تأخیر کلیک و استفاده از fingerprint های جعلی رفتار انسانی را تقلید می‌کنند ⁷.
- **استفاده مجدد از توکن/نشست:** مشابه متن‌محور، توکن تولید شده پس از حل تصویر می‌تواند برای دسترسی به صفحات دیگر استفاده شود.
- **حملات یادگیری تقویتی:** پژوهش‌های جدید از مدل‌های vision-language (VLM) برای حل چند مرحله‌ای CAPTCHA های تعاملی (مانند کشیدن اسلایدر) استفاده کرده‌اند؛ مجموعه داده MCA-Bench نشان می‌دهد این مدل‌ها می‌توانند بسیاری از CAPTCHA های چندمرحله‌ای را بشکنند ⁸.

۱.۳ CAPTCHA های صوتی (Audio-Based)

- **ساختار:** برای کاربران دارای مشکلات بینایی، صوتی از ارقام یا کلمات با نویز زمینه پخش می‌شود.
- **روش‌های حمله:**
- **تشخیص گفتار:** سرویس‌های مدرن ASR می‌توانند صدای CAPTCHAs را فیلتر و محتوای آن را استخراج کنند ⁹.
- **استفاده از مدل‌های adversarial برای حذف نویز:** مهاجمان با استفاده از فیلترها و شبکه‌های عمیق، نویز افزوده را حذف کرده و صدای واضحی برای ASR تولید می‌کنند.

۱.۴ CAPTCHA های منطقی/متنی و بازی‌ها

- **ساختار:** شامل سوالات منطقی، معما، بازی‌های ساده یا تست‌های «انسان/آسان/ماشین سخت» مانند IllusionCAPTCHA است.
- **روش‌های حمله:**
- **مدل‌های زبان بزرگ (LLM):** پژوهش ۲۰۲۵ نشان داده است که مدل‌های چندحالت Gemini و GPT-4o در بسیاری از CAPTCHA های منطقی می‌توانند موفق شوند؛ اگرچه IllusionCAPTCHA که از خطای دید و گزینه‌های گمراه‌کننده استفاده می‌کند، توانسته است LLM ها را ۱۰٪ فریب دهد ¹⁰.
- **راه‌حل‌های انسان‌محور:** معماها می‌توانند با برون‌سپاری به کارگران حل شوند.

۱.۵ حملات عمومی به سیستم CAPTCHA

- **پراکسی‌ها و Spoofing:** چرخش IP و تغییر agent مرورگر برای جلوگیری از تشخیص در reCAPTCHA ³.
- **ربات‌های headless و اتوماسیون:** ابزارهایی مانند Selenium/Puppeteer همراه با spoofing اثر انگشت می‌توانند تعاملات انسان را تقلید کنند ⁷.
- **حملات Cross-Site Request/Script Injection:** تزریق کد جاوااسکریپت در صفحه برای عبور از بررسی و ارسال پاسخ ساختگی.

۲. ارزیابی پژوهش‌های جدید درباره ضعف‌های CAPTCHA

پژوهش منتشر شده در مجله IRJMS سال ۲۰۲۴ به بررسی حملات علیه CAPTCHA پرداخته و سه دسته اصلی حمله را شرح می‌دهد:

- **الگوریتم‌های یادگیری ماشین:** با جمع‌آوری داده، استخراج ویژگی، آموزش CNN/RNN و ارزیابی، مدل قادر است الگوهای CAPTCHA را بیاموزد و دقت بالایی بدست آورد ¹.
- **تکنیک‌های OCR:** شامل پیش‌پردازش، بخش‌بندی، شناخت کاراکتر و پس‌پردازش بوده و برای CAPTCHA های متنی به کار می‌رود ².
- **حملات adversarial:** استفاده از تغییرات جزئی (perturbations) برای همراه کردن مدل‌های یادگیری ماشین و دور زدن سیستم ¹¹.

علاوه بر این، حملات مهندسی اجتماعی مانند فیشینگ و استفاده از crowdsourcing، کاربران واقعی را به حل CAPTCHA برای مهاجم وادار می‌کند.⁵

در تحلیل بزرگ‌مقیاس (MDPI (Electronics 2025)، ۱۳ ویژگی امنیتی در CAPTCHA‌های متنی شناسایی و تأثیر آن‌ها بر استفاده‌پذیری و مقاومت در برابر CNN‌ها بررسی شده است. ویژگی‌هایی مانند پیچش (warping)، چرخش، روی هم‌افتادگی کاراکترها، نویز، پس‌زمینه بافت‌دار و تغییر رنگ در دسته ضد-پردازش/ضد-بخش‌بندی قرار گرفته‌اند.¹² یافته‌ها نشان می‌دهد استفاده از حداقل ۷ ویژگی امنیتی می‌تواند تعادل مناسبی بین امنیت و استفاده‌پذیری ایجاد کند.¹³

۳. روش‌های ایمن‌سازی و سخت کردن CAPTCHA

برای مقابله با حملات فوق، مطالعات و تجربیات صنعتی چندین راهکار ارائه داده‌اند. در ادامه مهم‌ترین روش‌ها و توصیه‌ها آمده است.

۳.۱ پیچیده‌سازی چالش و ایجاد تنوع

- افزودن نویز و اعوجاج چندلایه: استفاده از اعوجاج‌های پیچیده (پیچش، چرخش، تغییر مقیاس و کشیدگی)، روی هم‌افتادگی کاراکترها و پس‌زمینه‌های بافت‌دار می‌تواند دقت حملات OCR و CNN را کاهش دهد.¹²
- استفاده از داده‌های معنی‌دار و بی‌معنی: در تولید CAPTCHA‌های دست‌نویس عربی، پژوهش MDPI 2023 نشان می‌دهد ترکیب کلمات واقعی و بی‌معنی و اعمال پنج تکنیک (Expectation Over perturbation Transformation, Scaled Gaussian Translation with Channel Shift, JSMA, Immutable Adversarial Noise و Connectionist Temporal Classification) مقاومت را افزایش می‌دهد.¹⁴
- ترکیب چند نوع چالش: تولید CAPTCHA‌هایی که نیاز به خواندن متن، انتخاب تصویر و پاسخ به سؤال منطقی دارند، چندین مهارت انسانی را درگیر می‌کند و حمله خودکار را دشوارتر می‌سازد.

۳.۲ به‌کارگیری تکنیک‌های adversarial به عنوان دفاع

تحقیقات اخیر از حملات adversarial به عنوان ابزار دفاعی بهره می‌برند:

- AdvCAPTCHA (USEC 2024) با استفاده از سه نوع perturbation صوتی – Volcano و Kenan, Devil – فایل‌های صوتی adversarial تولید کرد که نرخ موفقیت حملات ASR را از ۷۰٫۱٪ به ۰٫۲٪ کاهش داد و قابلیت تشخیص حملات را نیز فراهم نمود.¹⁵
- Adversarial Handwritten CAPTCHA: استفاده از تکنیک‌های JSMA، EOT و غیره برای افزودن نویز به تصاویر دست‌نویس و افزایش خطای مدل‌های تشخیص.¹⁶
- IllusionCAPTCHA (WWW 2025) از خطای دید و گزینه‌های گمراه‌کننده بهره می‌برد و توانست مدل‌های Gemini و GPT-4o را ۱۰۰٪ فریب دهد، در حالی که ۸۶٫۹۵٪ از کاربران انسانی در اولین تلاش موفق شدند.¹⁰

۳.۳ استفاده از تحلیل رفتاری و ارزیابی ریسک

- reCAPTCHA v3 و مشابه آن رفتار کاربر (حرکات ماوس، الگوهای کلید، IP) را جمع‌آوری و بر اساس آن نمره ریسک تعیین می‌کند؛ تنها در صورت شک، چالش نمایش داده می‌شود.¹⁷ راهنمای Radware پیشنهاد می‌کند سطوح مختلفی از شدت چالش براساس حساسیت عملیات و سابقه کاربر تنظیم شود.¹⁸
- نظارت و تحلیل مداوم: توصیه می‌شود آمار reCAPTCHA (نسبت قبولی/رد، نمره ریسک، تعداد چالش‌های ناموفق) به طور مستمر بررسی و تنظیمات براساس آن اصلاح شود.¹⁹

۳.۴ پازل‌های اثبات کار (Proof-of-Work)

- **Proof-of-Work در Friendly CAPTCHA:** این سرویس آلمانی با ایجاد پازل‌های رمزنگاری که در پس‌زمینه حل می‌شوند، کاربران را درگیر نمی‌کند. هنگام شروع پر کردن فرم، دستگاه کاربر یک پازل منحصر به فرد حل می‌کند و هنگام ارسال، پاسخ برای اعتبارسنجی ارسال می‌شود. این فرآیند چند ثانیه طول می‌کشد و حریم خصوصی را حفظ می‌کند.²⁰ پیاده‌سازی مبتنی بر PoW هزینه محاسباتی زیادی به ربات‌ها تحمیل می‌کند و مناسب GDPR است.
- **NgCaptcha (2018-2025):** ترکیبی از PoW و چالش انتخاب تصویر ارائه می‌دهد: ابتدا مرورگر یک هش سبک را حل می‌کند و سپس کاربر باید بین تصاویر توهم‌آمیز انتخاب کند. این طراحی دو بعدی، هزینه حمله را افزایش می‌دهد و همچنان تجربه کاربری خوبی دارد.^{21 22}
- **مزایای PoW:** طبق سند W3C، چالش‌های PoW می‌توانند براساس شهرت کاربر دشوارتر یا آسان‌تر شوند و تأثیر کمی بر تجربه کاربر واقعی داشته باشند، ولی برای ربات‌ها هزینه‌زا هستند.²³

۳.۵ روش‌های غیر تعاملی و جایگزین‌های CAPTCHA

سند W3C درباره «Inaccessibility of CAPTCHA» چند رویکرد پیشنهادی برای حذف یا کاهش CAPTCHA ارائه می‌کند:

- **تحلیل مبتنی بر شواهد و heuristic:** بررسی حجم داده، صفحاتی که کاربر بازدید می‌کند، الگوی ورود داده و سایر امضاها برای تشخیص ربات‌ها.²⁴
- **Honeypotها:** ایجاد فیلدی مخفی که تنها ربات‌ها آن را پر می‌کنند؛ پر شدن این فیلد نشان‌دهنده بات بودن است.²⁵
- **حساب‌های محدود (Limited-Use):** محدود کردن تعداد درخواست‌های یک کاربر یا حساب جدید در روز برای کاهش ارزش حمله.²⁶
- **زیرساخت کلید عمومی (PKI):** استفاده از گواهی‌نامه‌های دیجیتال برای تأیید هویت کاربر؛ اما نگرانی‌های حریم خصوصی وجود دارد.²⁷
- **نسخه‌های غیرتعاملی reCAPTCHA v3:** این نسخه با تخصیص نمره ریسک و بدون نمایش چالش، دسترسی می‌دهد و از نظر دسترسی‌پذیری مناسب‌تر است.²⁸
- **روش‌های اثبات کار، heuristic و honeypot را می‌توان به‌طور ترکیبی برای افزایش مقاومت استفاده کرد.**

۳.۶ بهترین شیوه‌ها برای پیاده‌سازی reCAPTCHA (یا CAPTCHA مشابه)

طبق راهنمای Radware، رعایت موارد زیر توصیه می‌شود:

1. **ارزیابی ریسک زمینه‌ای:** فقط در صفحاتی که احتمال سوءاستفاده در آن‌ها زیاد است از CAPTCHA استفاده شود و شدت چالش بر اساس سابقه کاربر تنظیم گردد.²⁹
2. **تنظیم آستانه‌های نمره:** در reCAPTCHA v3، نمره پایین‌تر نشان‌دهنده احتمال بیشتر بات است؛ آستانه‌ها باید بر اساس حساسیت عملیات تعیین شود.³⁰
3. **مدیریت امن کلیدها:** کلید خصوصی reCAPTCHA باید فقط در سمت سرور ذخیره شود و به‌طور دوره‌ای چرخش پیدا کند.³¹
4. **نظارت و تحلیل مداوم:** آمار reCAPTCHA باید مانیتور شده و در صورت مشاهده افزایش نرخ رد یا خطا، تنظیمات اصلاح شود.¹⁹
5. **اعتبارسنجی سمت سرور:** پاسخ reCAPTCHA باید در سمت سرور اعتبارسنجی و با سایر روش‌های امنیتی مانند محدودسازی IP، تشخیص اثر انگشت مرورگر و احراز دو مرحله‌ای ترکیب شود.³²

۳.۷ دسترس‌پذیری و تجربیات کاربری

- **چالش‌های دسترس‌پذیری:** مقاله A11Y Collective نشان می‌دهد CAPTCHAs می‌توانند مشکلات بزرگی برای کاربران دارای نقص بینایی، شنوایی، حرکتی و شناختی ایجاد کنند، مانند دشوار بودن خواندن متن‌های تحریف‌شده، کیفیت پایین فایل‌های صوتی و نیاز به حرکات دقیق ماوس³³. بنابراین طراحی باید شامل گزینه‌های جایگزین، متن جایگزین و زمان‌بندی مناسب باشد.
- **پیشنهادهای دسترس‌پذیر:** ارائه روش‌های غیر تعاملی (شبهه reCAPTCHA v3)، استفاده از PoW و تحلیل رفتار به جای حل معما، و طراحی رابط‌های ساده و قابل استفاده همراه با گزینه‌های صوتی مناسب.

۴. طراحی CAPTCHA کاملاً امن

با توجه به پیشرفت‌های اخیر در حملات و پژوهش‌ها، طراحی CAPTCHA ای که «همه جور» امن باشد، نیازمند ترکیب چندین تکنیک است:

1. **ترکیب مکانیزم‌های اثبات کار و چالش AI-Hard:** ابتدا یک پازل هش سبک توسط مرورگر حل شود (PoW) تا ربات‌ها هزینه‌زا شوند؛ سپس یک چالش پیچیده مانند IllusionCAPTCHA یا بازی منطقی ارائه شود که برای انسان‌ها آسان اما برای مدل‌های AI سخت است^{21 10}.
2. **استفاده از چرخه‌های متغیر و تصادفی:** ایجاد تنوع بالا در تصاویر، متن، ترتیب مراحل و عدم تکرار الگو؛ استفاده از داده‌های واقعی و بی‌معنی، اعوجاج‌های تصادفی و نویز.
3. **ادغام تحلیل رفتاری:** ارزیابی حرکات ماوس، سرعت تایپ، الگوهای کلیک و استفاده از یادگیری ماشین برای نمره‌دهی ریسک؛ تنها در صورت رفتار مشکوک چالش نمایش داده شود²⁹.
4. **اعمال adversarial noise:** ایجاد مثالی‌های adversarial در تصاویر/صوت‌ها به گونه‌ای که انسان تفاوت را احساس نکند اما مدل‌های یادگیری ماشین دچار خطا شوند¹⁵.
5. **ترکیب honeypot و Heuristics:** قرار دادن فیلدهای مخفی و تحلیل رفتار کاربر جهت تشخیص ربات‌های ساده؛ فیلد مخفی در صورت پر شدن توسط ربات، درخواست را رد می‌کند²⁵.
6. **محدودسازی نرخ و سیاست‌های دسترسی:** اعمال محدودیت روی تعداد دفعات ارسال فرم، استفاده از صف‌های تأخیری، و ایجاد حساب‌های محدود. این روش‌ها اغلب بدون CAPTCHA نیز می‌توانند حملات را کاهش دهند²⁶.
7. **مدیریت کلیدها و سرور امن:** حفاظت از کلیدهای مخفی، استفاده از TLS و اعتبارسنجی سمت سرور.
8. **پایش و به‌روزرسانی مداوم:** الگوریتم‌های حمله و مدل‌های AI به سرعت پیشرفت می‌کنند؛ بنابراین سیستم CAPTCHA باید به صورت دوره‌ای به‌روزرسانی شده، داده‌های جدید جمع‌آوری و الگوریتم‌ها اصلاح شوند.

۵. جمع‌بندی و توصیه‌های عملی

1. **فهم تهدیدات:** حمله‌کنندگان از ML، OCR، adversarial attacks، مهندسی اجتماعی و روش‌های ساده مانند تون‌کن Reuse برای عبور از CAPTCHA استفاده می‌کنند^{1 3}.
2. **پیاده‌سازی چندلایه دفاعی:** تنها یک نوع CAPTCHA هرگز کافی نیست. ترکیبی از PoW، چالش‌های چندمرحله‌ای و تحلیل رفتاری توصیه می‌شود²².
3. **دسترس‌پذیری را جدی بگیرید:** از روش‌های غیرتعاملی، گزینه‌های صوتی با کیفیت و ارائه پیام‌های متنی جایگزین استفاده کنید. استانداردهای WCAG و پیشنهادات W3C را رعایت نمایید^{28 33}.
4. **مدیریت کلیدها و پیکربندی:** آستانه‌های reCAPTCHA v3 بر اساس ریسک تنظیم و کلیدهای خصوصی به‌طور امن ذخیره شوند³⁴.
5. **نظارت و به‌روزرسانی:** بررسی منظم میزان موفقیت انسان‌ها و ربات‌ها، به‌روزرسانی تصاویر و صوت‌ها، و استفاده از داده‌های جدید ضروری است.

نتیجه‌گیری

تحقیقات نشان می‌دهد که هیچ CAPTCHA واحدی نمی‌تواند به تنهایی جلوی تمام حملات را بگیرد. پیشرفت‌های هوش مصنوعی و توان پردازشی ربات‌ها، CAPTCHA‌ای سنتی را تضعیف کرده‌اند. راهکار مؤثر شامل رویکرد چندلایه است: استفاده از پازل‌های اثبات کار برای افزایش هزینه حمله، ایجاد چالش‌های دیداری/منطقی پیچیده که برای AI مشکل باشند، به‌کارگیری نويزهای adversarial، تحلیل رفتاری و سیاست‌های محدودسازی. با رعایت اصول دسترس‌پذیری و حفظ حریم خصوصی، می‌توان سیستم‌هایی طراحی کرد که هم برای کاربران واقعی ساده و سریع و هم برای ربات‌ها سخت و هزینه‌بر باشد. این گزارش با بررسی تمام منابع موجود تا پایان سال ۲۰۲۵، تصویری جامع از وضعیت کنونی و آینده احتمالی CAPTCHA ارائه می‌دهد و راهنمایی عملی برای پیاده‌سازی و ایمن‌سازی آن فراهم می‌کند.

Synopsis 11 5 2 1

https://www.irjms.com/wp-content/uploads/2024/07/Manuscript_IRJMS_0828_WS.pdf

| How CAPTCHA Solvers Are Changing the Game: Bypass, Decode & Recognize | by hrogy 9 7 6 3

Medium

<https://medium.com/@joryg21/how-captcha-solvers-are-changing-the-game-bypass-decode-recognize-a53b1a343719>

arXiv:2502.05461v2 [cs.CR] 21 Feb 2025 10 4

<https://arxiv.org/pdf/2502.05461>

MCA-Bench: A Multimodal Benchmark for Evaluating CAPTCHA Robustness Against VLM-based Attacks 8

<https://arxiv.org/html/2506.05982v4>

Revisiting Text-Based CAPTCHAs: A Large-Scale Security and Usability Analysis Against CNN-Based 13 12

Solvers

<https://www.mdpi.com/2079-9292/14/22/4403>

Enhancing Security of Online Interfaces: Adversarial Handwritten Arabic CAPTCHA Generation 16 14

<https://www.mdpi.com/2076-3417/15/6/2972>

usec2024-35-paper.pdf 15

<https://www.ndss-symposium.org/wp-content/uploads/usec2024-35-paper.pdf>

reCAPTCHA: How It Works, Pros/Cons & Best Practices [2025] | Radware 34 32 31 30 29 19 18 17

<https://www.radware.com/cyberpedia/bot-management/recaptcha>

Friendly Captcha - Privacy-First Bot Protection 20

<https://friendlycaptcha.com>

NgCaptcha: A CAPTCHA Bridging the Past and the Future 22 21

<https://arxiv.org/html/2512.16223v1>

Inaccessibility of CAPTCHA 28 27 26 25 24 23

<https://w3c.github.io/captcha-accessibility>

How to Make CAPTCHA Accessible: A Hands-On Guide - The A11Y Collective 33

<https://www.a11y-collective.com/blog/accessible-captcha>